

# Production deployment guide

CAS API, Student Portal and Collaborator Portal on Microsoft Azure

| COLLABORATORS                                                       | STUDENTS                                               |
|---------------------------------------------------------------------|--------------------------------------------------------|
| Microsoft Entra sign-in<br>Document review and invitations          | Email/password sign-in<br>Admission files and progress |
| cas-collaborators-prod                                              | cas-students-prod                                      |
| CAS API • authorization • HubSpot • Resend • Dataverse • SharePoint |                                                        |

Detailed click-by-click plan • required code changes • security cautions • test and rollback checklist

Prepared for the current repositories on main  
27 August 2026 • America/Costa\_Rica

# Contents

1. Executive decision and target architecture
  2. Current readiness and go/no-go gates
  3. Azure foundation: resource group, registry, Key Vault and environment
  4. Build and deploy the three containers
  5. Production configuration for each service
  6. Domains, TLS and Microsoft Entra authentication
  7. HubSpot intake and Resend delivery
  8. Snowflake: what it should and should not do now
  9. CI/CD, monitoring, backups and rollback
  10. End-to-end acceptance tests and launch sequence
  11. Code changes: completed and still required
  12. Risk register and final production checklist
- Appendix A. Environment variable matrix
- Appendix B. Official documentation links

**Important**

This is an implementation guide, not proof that the Azure tenant, DNS zone, Entra app registration, HubSpot workflow or Resend domain is already configured. Every external setting must be verified in the named portal before production traffic is enabled.

# 1. Executive decision and target architecture

- Recommended hosting: Microsoft Azure Container Apps in one production environment.
  - One external HTTPS app for the CAS API on port 8080.
  - One external HTTPS Streamlit app for students on port 8501.
  - One external HTTPS Streamlit app for collaborators on port 8501, with sticky sessions enabled.
- Keep Dataverse and SharePoint as the operational source of truth for the first production release.
  - The current code already reads and writes Dataverse and SharePoint.
  - No current repository imports or connects to Snowflake.
  - Replacing Dataverse with Snowflake would require a new data model, migrations, authorization rules, reconciliation and regression testing.
- Use Snowflake later for analytics, immutable event history, deliverability analysis and management reporting.
  - Do not put student sign-in, document workflow state or immediate webhook writes on Snowflake for this launch.
  - If Snowflake is added, send an asynchronous copy of selected events after the operational transaction succeeds.
- Use Azure Container Registry for images and Azure Key Vault references for secrets.
  - Never copy local .env files into a container image.
  - Use managed identity for image pulls and Key Vault access where supported.

## Proposed production endpoints

| Service             | Public URL                                                              | Container port | Primary users            |
|---------------------|-------------------------------------------------------------------------|----------------|--------------------------|
| CAS API             | <a href="https://api.cas.cr">https://api.cas.cr</a>                     | 8080           | Portals, HubSpot, admins |
| Student Portal      | <a href="https://estudiantes.cas.cr">https://estudiantes.cas.cr</a>     | 8501           | Students                 |
| Collaborator Portal | <a href="https://colaboradores.cas.cr">https://colaboradores.cas.cr</a> | 8501           | CAS @cas.cr coworkers    |

### Release posture

Deploy to a staging revision first. Do not send real HubSpot or invitation traffic until the P0 gates in section 2 pass. Keep production on a single API replica initially because rate limits and caches are currently process-local.

# 2. Current readiness and go/no-go gates

## Evidence already obtained

- CAS API suite: 35 tests passed.
- Student Portal suite: 39 tests passed with Streamlit 1.60.0.
- Collaborator Portal suite: 11 tests passed with Streamlit 1.60.0, including the one-click invitation test.
- Local smoke test reached API, collaborator and student health endpoints and found the five QA students.
- Dataverse and SharePoint dependency health returned OK after network connectivity was restored.
- Microsoft collaborator authentication has completed successfully in the local flow after the earlier socket restriction was removed.
- Dockerfiles and .dockerignore files now exist for all three services; the API also accepts Azure's PORT variable and binds externally in production.

- This computer does not have Docker installed, so image builds still need to run in Azure Container Registry or GitHub Actions.

## P0 — must pass before real production traffic

- Complete an end-to-end staging run using real Microsoft, Dataverse, SharePoint, HubSpot and a controlled real mailbox.
  - Test collaborator sign-in, student invitation, temporary-password redirect, new password, forgot-password and document upload/review.
  - Record the actual request IDs and verify there are no raw credentials or passwords in logs.
- Decide and implement the production session-cookie posture.
  - The code now adds Secure outside local, but the custom cookie is still written by JavaScript and therefore cannot be HttpOnly.
  - The cookie contains the signed API user token. A future cross-site scripting defect could expose it.
  - Preferred fix: a small server-side authentication/BFF layer or an identity-aware reverse proxy that sets HttpOnly, Secure cookies. Until then, restrict pilot access, review all unsafe HTML/JavaScript, and apply a strict Content-Security-Policy at the edge.
- Confirm production secrets and exact URLs.
  - CAS\_API\_AUTH\_TOKEN, CAS\_API\_USER\_TOKEN\_SECRET, CAS\_API\_PASSWORD\_RESET\_SECRET and AUTH\_COOKIE\_SECRET must be long, independent random values.
  - CAS\_PORTAL\_URL must be https://estudiantes.cas.cr.
  - CAS\_MICROSOFT\_REDIRECT\_URI must exactly match the redirect URI in Microsoft Entra.
  - CAS\_HUBSPOT\_WEBHOOK\_PUBLIC\_URL must exactly match the HTTPS URL HubSpot calls.
- Run the Dataverse schema preparation script for temporary-access fields and verify the columns with a non-production record.
- Verify DNS and managed TLS for all three hostnames before updating OAuth, HubSpot or email links.

## P1 — required for a supported launch

- Add Resend delivery webhooks and persist email ID/status; today an HTTP success only proves Resend accepted the request, not that the mailbox received it.
- Create alerts for API 5xx, container restarts, failed health checks, HubSpot webhook failures, Resend bounces/suppressions and dependency latency.
- Use single-revision mode, minimum one replica, and sticky sessions on both Streamlit apps.
- Keep the API maximum replica count at one until the in-memory rate limiter is moved to shared storage such as Azure Cache for Redis.
- Add malware scanning or a documented quarantine/review process for uploaded files; extension, size and signature checks are not antivirus scanning.
- Create a staging environment or staging revision with separate test identities and a non-production Resend route.

# 3. Azure foundation: resource group, registry, Key Vault and environment

## 3.1 Choose subscription, region and names

- Use one Azure subscription with billing alerts and a dedicated resource group, for example rg-cas-prod.

- Use one region for Container Apps, Registry, Key Vault and Log Analytics. Measure latency from Costa Rica and confirm organizational data-residency requirements before choosing.
- Suggested names: `acrcasprod<unique>`, `kv-cas-prod-<unique>`, `cae-cas-prod`, `law-cas-prod`, `cas-api-prod`, `cas-students-prod` and `cas-collaborators-prod`.
- Add tags: `Environment=Production`, `Application=CAS-Portal`, `Owner=<name>`, `CostCenter=<value>`.

## 3.2 Create the resource group — where to click

- Open `portal.azure.com` and use the top search bar for Resource groups.
- Select Create. Choose the paid subscription, enter `rg-cas-prod`, select the chosen region, then Review + create and Create.
- Open Cost Management + Billing > Budgets and create a monthly budget with alerts at 50%, 80% and 100% to named administrators.

## 3.3 Create Azure Container Registry

- Azure portal > Create a resource > Infrastructure services > Container Registry > Create.
- Select `rg-cas-prod`, choose a globally unique lowercase registry name, the same region, and Standard SKU.
- For Domain name label scope, use Tenant Reuse or the organization's chosen secure scope.
- Leave Admin user disabled. Prefer Microsoft Entra/RBAC and managed identity for image pulls.
- After deployment, open the registry > Repositories. The expected repositories will be `cas-api`, `cas-students` and `cas-collaborators`.

## 3.4 Create Key Vault and secrets

- Azure portal > Create a resource > Key Vault > Create. Place it in `rg-cas-prod`, select Standard, enable soft delete and purge protection, and use Azure role-based access control.
- Inside the vault: Objects > Secrets > Generate/Import. Create one secret per sensitive value; do not paste a whole `.env` file into one secret.
- Use descriptive names such as `cas-api-auth-token`, `cas-user-token-secret`, `dataverse-client-secret`, `sharepoint-client-secret`, `resend-api-key` and `auth-cookie-students`.
- Assign each Container App a system-managed identity. Grant only Key Vault Secrets User on this vault, and only to the apps that require the specific references.
- When rotating a Key Vault-backed Container Apps secret, restart the active revision or create a new revision; changing a secret alone does not automatically reload existing replicas.

## 3.5 Create the Container Apps environment

- Azure portal > search Container Apps > Create > Container App.
- On Basics, choose `rg-cas-prod` and the region. Create a new Container Apps environment named `cae-cas-prod` and connect it to a Log Analytics workspace named `law-cas-prod`.
- Use Workload profiles environment with Consumption initially unless your security/networking requirements require a dedicated profile or private endpoint.
- All three apps should share this environment so they share logging, DNS and an operational boundary.

## 4. Build and deploy the three containers

### Preferred first build: Azure Container Registry build

Docker is not installed on the current PC. ACR can build each repository from its Dockerfile without a local Docker daemon. Use Azure Cloud Shell or a workstation with Azure CLI.

```
az login
az account set --subscription "<SUBSCRIPTION_ID>"

# From each repository root:
az acr build --registry <ACR_NAME> --image cas-api:<GIT_SHA> .
az acr build --registry <ACR_NAME> --image cas-students:<GIT_SHA> .
az acr build --registry <ACR_NAME> --image cas-collaborators:<GIT_SHA> .
```

- Use an immutable Git commit SHA as the image tag. Do not deploy only latest; it makes rollback ambiguous.
- The API image installs Node.js because the embedded automatching engine invokes a JavaScript runner.
- The student and collaborator images pin Streamlit 1.60.0 through requirements.txt.
- After each build, Registry > Repositories > select repository > Tags and confirm the new SHA tag exists.

### Create each Container App — common portal steps

- Azure portal > Container Apps > Create > Container App.
- Basics: select rg-cas-prod, the existing cae-cas-prod environment and Deployment source = Container image.
- Container: clear Use quickstart image, choose Azure Container Registry, select the registry, repository and immutable tag.
- Ingress: Enabled, Accepting traffic from anywhere, HTTP transport, Allow insecure connections = Off.
- Review + create > Create. Open Overview and test the generated azurecontainerapps.io URL before adding custom DNS.

| App                    | Image              | Target port | Session affinity | Initial replicas |
|------------------------|--------------------|-------------|------------------|------------------|
| cas-api-prod           | cas-api:           | 8080        | Off              | min 1 / max 1    |
| cas-students-prod      | cas-students:      | 8501        | On               | min 1 / max 2    |
| cas-collaborators-prod | cas-collaborators: | 8501        | On               | min 1 / max 2    |

### Health probes

- CAS API
  - Startup: HTTP GET /health on port 8080; allow at least 20 seconds.
  - Liveness: HTTP GET /health; do not make liveness depend on Dataverse or SharePoint.
  - Use /health/dependencies for external monitoring and alerting, not to kill every replica during a Microsoft outage.
- Both Streamlit portals
  - Startup/liveness/readiness endpoint: /\_stcore/health on port 8501.
  - Enable session affinity: Container App > Networking > Ingress > Session affinity > Enabled > Save.

## 5. Production configuration for each service

### How to enter variables

- Open the Container App > Security > Secrets > Add. Prefer Type = Key Vault reference for sensitive values.

- Then go to Revisions and replicas > Create new revision > edit the container > Environment variables > Add.
- For a secret-backed variable, select Source = Reference a secret. For a public setting, select Manual.
- Create the revision. Verify it is healthy before directing traffic to it.

## CAS API — required public settings

- CAS\_ENVIRONMENT=prod; CAS\_API\_HOST=0.0.0.0; CAS\_API\_PORT=8080; CAS\_API\_REQUIRE\_AUTH=1; CAS\_API\_TIMING=0.
- Dataverse URL, tenant ID and client ID; SharePoint hostname, site path and base folder.
- RESEND\_FROM\_EMAIL=CAS Student Services <notifications@cas.cr> and CAS\_PORTAL\_URL=https://estudiantes.cas.cr.
- CAS\_HUBSPOT\_ALLOWED\_FORM\_IDS must contain only approved production form IDs.
- CAS\_HUBSPOT\_WEBHOOK\_PUBLIC\_URL=https://api.cas.cr/webhooks/hubspot/form-submission.
- Leave CAS\_RATE\_LIMIT\_DISABLED unset. Leave local/test endpoints disabled by CAS\_ENVIRONMENT=prod.
- Keep automatching UI/API/write flags off until the Dataverse contract and result parity are accepted in staging.

## CAS API — required secrets

- CAS\_API\_AUTH\_TOKEN: shared service credential used by both portals; generate at least 32 random bytes.
- CAS\_API\_USER\_TOKEN\_SECRET: independent signing key for user tokens.
- CAS\_API\_PASSWORD\_RESET\_SECRET: independent password-change authorization key.
- CAS\_API\_DATAVERSE\_CLIENT\_SECRET and CAS\_API\_SHAREPOINT\_CLIENT\_SECRET.
- RESEND\_API\_KEY with the minimum sending permissions and restricted domain when available.
- CAS\_HUBSPOT\_CLIENT\_SECRET from the HubSpot developer app used for request signing.

## Student Portal

- CAS\_ENVIRONMENT=prod; CAS\_API\_BASE\_URL=https://api.cas.cr.
- CAS\_API\_AUTH\_TOKEN must reference the same value used by the API.
- AUTH\_COOKIE\_SECRET must be unique to the student portal and must not equal the collaborator cookie secret.
- Do not define CAS\_TEST\_STUDENT\_ID or CAS\_TEST\_STUDENT\_NAME in production.
- Keep Streamlit CORS and XSRF protection enabled; configure allowed hosts/origins only after the final hostname is known.

## Collaborator Portal

- CAS\_ENVIRONMENT=prod; CAS\_API\_BASE\_URL=https://api.cas.cr; CAS\_API\_AUTH\_TOKEN shared with API.
- AUTH\_COOKIE\_SECRET unique to collaborators; CAS\_REVIEWER\_IDLE\_TIMEOUT\_MINUTES=60 or the approved policy.
- CAS\_MICROSOFT\_TENANT\_ID, CAS\_MICROSOFT\_CLIENT\_ID, CAS\_MICROSOFT\_CLIENT\_SECRET and CAS\_MICROSOFT\_REDIRECT\_URI=https://colaboradores.cas.cr.
- Leave CAS\_STREAMLIT\_UI\_DEBUG unset and local reviewer/mock access absent.
- Leave CAS\_AUTOMATCHING\_UI\_ENABLED=0 until API and write flags are approved.

**Secret rule**

The production container must not contain `.env.api.local`, `.env.streamlit.local`, `.env.local` or `.streamlit/secrets.toml`. The added `.dockerignore` files exclude environment files, but verify the image contents during CI as a release gate.

## 6. Domains, TLS and Microsoft Entra authentication

### 6.1 Bind each custom domain

- Open the Container App > Networking > Ingress and confirm ingress is enabled and Allow insecure connections is off.
- Open Networking > Custom domains > Add custom domain.
- Choose Managed certificate. For a subdomain, Azure will show a CNAME target and a TXT verification record.
- At the DNS provider for `cas.cr`, create the exact CNAME and TXT records for `api`, `estudiantes` and `colaboradores`.
- Return to Azure and validate. The CNAME must point directly to the generated Container App hostname; an intermediate proxy can block managed-certificate issuance or renewal.
- If the root domain has CAA records, allow DigiCert with 0 issue `digicert.com`.
- Wait for certificate status Succeeded, then open each `https://` URL in a private browser window and inspect the certificate name and expiry.

### 6.2 Configure Microsoft Entra for collaborator sign-in

- Azure portal > Microsoft Entra ID > App registrations > select the CAS collaborator application.
- Overview: copy Directory (tenant) ID and Application (client) ID into the corresponding Container App settings.
- Authentication > Add a platform > Web > Redirect URIs: add `https://colaboradores.cas.cr` exactly. Keep `http://localhost:8501` only if local development still needs it.
- API permissions: confirm delegated Microsoft Graph User.Read and grant admin consent if tenant policy requires it.
- Certificates & secrets: create a new client secret with an owner and expiration date, copy its value once into Key Vault, and set a rotation reminder before expiry.
- Supported account types should normally be single tenant for CAS. Confirm the code's `@cas.cr` enforcement remains active as defense in depth.
- Test in a private browser: sign in, deny consent once, retry, use an unauthorized non-CAS account and confirm every failure shows the safe administrator message rather than a raw socket/OAuth error.

### 6.3 Browser and session cautions

- Streamlit uses WebSockets; keep HTTP transport auto and session affinity enabled for each portal.
- The code now marks custom auth cookies Secure in production and uses separate names: `cas_student_auth` and `cas_reviewer_auth`.
- SameSite=Lax is appropriate for top-level Entra redirects, but the custom cookie remains JavaScript-readable. Treat the HttpOnly redesign as a production-security work item.
- If Azure Front Door or another proxy is added, preserve Host and forwarded-protocol headers because HubSpot signature reconstruction and OAuth redirect URLs depend on the public HTTPS host.



## 7. HubSpot intake and Resend delivery

### 7.1 Configure the HubSpot workflow

- HubSpot > More (if shown) > Automation > Workflows > open or create the applicant/contact workflow.
- Set enrollment to the approved form-submission condition. Use a small internal test list before enabling automatic enrollment.
- In the workflow editor select + > Data ops > Send a webhook.
- Method = POST; URL = `https://api.cas.cr/webhooks/hubspot/form-submission`; HTTPS is required.
- Authentication = Request signature and select the production developer app whose client secret is stored as `CAS_HUBSPOT_CLIENT_SECRET`.
- Choose a customized request body that includes form ID, email, first name, last name and supported stay/date fields. Keep property names aligned with `Documentacion/QA/hubspot_form_webhook_testing.md`.
- Select Test action. In Request, verify the signature header and body. In Response, require 2xx and inspect the student result without exposing secrets.
- Publish only after CAS API logs show a single idempotent create/update and the approved form ID is on the allowlist.

### Current HubSpot behavior and caution

- The API validates the HubSpot workflow v2 signature, the exact public URI, the allowlisted form ID and the supported payload fields.
- Create/update is idempotent by normalized email, which prevents duplicate students for repeated delivery.
- Signature v2 does not add timestamp-based replay protection in the current implementation. A captured valid request can be replayed and may reapply older field values.
- Recommended code change: persist HubSpot execution/event ID plus payload hash and received time; reject an already-processed event and define a rule that stale events cannot overwrite newer student data.

### 7.2 Finish Resend production configuration

- Resend dashboard > Domains > select `cas.cr`. Confirm the domain and DKIM records are Verified.
- Verify the Return-Path/sending subdomain records shown by Resend. DNS observed during local review had DKIM but no visible `_dmarc.cas.cr` TXT response; create and roll out DMARC deliberately after confirming all legitimate senders.
- Use the friendly sender CAS Student Services <`notifications@cas.cr`> and the HTTPS student-portal link.
- Resend dashboard > API Keys: use a production sending key with the smallest useful scope. The current sending-only key cannot list domain status through the API; use the dashboard or a separately controlled full-access key for administrative verification.
- Send to a controlled Gmail or Outlook mailbox, not `example.com` and not a disposable domain. Verify inbox/spam, From, Reply-To policy, links, mobile layout and plain-text alternative.

### Required email-delivery code change

- Persist the Resend email ID returned by the send API with type, student ID, recipient hash, created time and `status=accepted`.
- Add a signed Resend webhook endpoint for `email.sent`, `email.delivered`, `email.bounced`, `email.failed`, `email.suppressed`, `email.delivery_delayed` and `email.complained`.
- Persist each event idempotently and update the invitation record. Show 'accepted for delivery' immediately, then delivered/bounced status in the collaborator portal.

- Do not expose the temporary password in logs or webhook payload storage. Retain only email provider ID and safe metadata.
- Today, the API rolls back the password only when Resend fails synchronously. An asynchronous bounce can leave a rotated temporary password that the user never received; add a resend/reissue action and clear operational guidance.

## 8. Snowflake: what it should and should not do now

### Decision

Your paid Snowflake account is useful, but it is not needed to host these applications. Azure runs the containers. Dataverse and SharePoint currently hold operational state. Introduce Snowflake only after the production workflow is stable.

### Good phase-two Snowflake uses

- Daily analytics copy of student lifecycle state, with only fields approved for reporting.
- Append-only HubSpot webhook audit and Resend delivery-event history.
- Operational dashboards: invitations accepted/delivered/bounced, time in each admission phase, review turnaround and upload error rate.
- Data-quality reconciliation between HubSpot contacts and Dataverse students.

### Do not use Snowflake for these launch paths

- Do not move password hashes, reset tokens or live session tokens to Snowflake.
- Do not make a student login or document upload wait for a Snowflake warehouse to resume.
- Do not replace Dataverse IDs or SharePoint item references without a versioned migration and rollback plan.

### Optional Snowflake setup — where to click

- Snowsight > Compute > Warehouses > Warehouse: create CAS\_ANALYTICS\_XS, size X-Small, auto-suspend 60 seconds, auto-resume on, initially Suspended.
- Snowsight > Projects > Worksheets > +: run reviewed SQL to create CAS\_ANALYTICS and schemas RAW, CURATED and AUDIT.
- Snowsight > Governance & security > Users & roles > Roles > + Role: create CAS\_INGEST\_ROLE and grant only warehouse usage plus insert/select on required schemas.
- Create a TYPE=SERVICE user. Prefer Snowflake Workload Identity Federation with Microsoft Entra/Azure managed identity when the Python connector and account support it; it avoids long-lived passwords and key files.
- If WIF is not ready, use key-pair authentication, store the private key in Key Vault, assign a dedicated role and schedule rotation. Never use ACCOUNTADMIN from application code.
- Governance & security > Network policies > Network Rules: restrict ingress only after confirming stable Azure egress/private connectivity so you do not lock out the workload or administrators.

### Code needed only when Snowflake is approved

- Add snowflake-connector-python at a pinned, tested version to a separate analytics worker, not the request path.
- Create an outbox/event table in the operational store and an Azure Container Apps Job that batches events to Snowflake with retries and deduplication.
- Define data classification, retention, masking and deletion rules before copying student information.

- Add reconciliation metrics and a dead-letter path; a Snowflake outage must not break HubSpot intake, invitation, login or document operations.

## 9. CI/CD, monitoring, backups and rollback

### 9.1 GitHub Actions with Azure OIDC

- Microsoft Entra ID > App registrations (or a user-assigned managed identity) > Federated credentials > Add credential > GitHub Actions deploying Azure resources.
- Select the exact GitHub organization, repository, entity type Branch and branch main. Create one credential per repository or use protected GitHub environments.
- Assign the deployment identity only the roles needed on rg-cas-prod and the registry; avoid Owner at subscription scope.
- GitHub repository > Settings > Security > Secrets and variables > Actions: add AZURE\_CLIENT\_ID, AZURE\_TENANT\_ID and AZURE\_SUBSCRIPTION\_ID. These IDs are identifiers, not client secrets.
- Create a production GitHub Environment requiring manual approval and limit deployments to main.

### Pipeline gates for each repository

- Checkout exact commit; install pinned dependencies; run unittest discover; fail on any test.
- Run secret scanning, dependency/vulnerability scanning and Dockerfile/image scanning.
- Build and push image tagged with commit SHA; never overwrite an existing SHA tag.
- Deploy a new Container Apps revision with zero production traffic, then run health and smoke tests against its revision/label URL.
- Require approval, shift traffic to the new revision, and monitor 5xx/latency/restarts for at least 15 minutes.
- Keep the previous image and revision available for immediate rollback.

### 9.2 Monitoring and alerts

- Container App > Monitoring > Log stream: check Console and System logs for startup failures and dependency errors.
- Container App > Monitoring > Metrics: watch Requests, Response time, Replicas, CPU, Memory and Restart count.
- Log Analytics > Logs: build queries for HTTP 5xx, auth failures by safe code, HubSpot status, Resend status and Microsoft dependency duration.
- Azure Monitor > Alerts > Create > Alert rule: notify a shared operations group for repeated 5xx, no healthy replicas, restart loops, dependency failures and high latency.
- Log identifiers should remain hashed/stable where already implemented; never log passwords, OAuth codes, access tokens, bearer tokens, client secrets or uploaded file contents.

### 9.3 Backup and recovery

- Confirm Dataverse environment backup/restore policy with the tenant administrator and practice restoring to a sandbox.
- Confirm SharePoint retention, version history and recycle-bin policy for the production document library.
- Export Azure configuration as Bicep/Terraform before launch so resources can be recreated consistently.
- Keep secrets versioned in Key Vault and document who can recover/rotate them; never put secret values in the runbook.
- Define recovery time objective, recovery point objective and the named decision-maker for rollback.

## 9.4 Rollback procedure

- Stop new HubSpot enrollments if intake is corrupting data; do not delete the workflow history.
- Container App > Revisions and replicas: reactivate the last known-good revision and route 100% traffic to it, or redeploy the last known-good SHA image.
- If a schema change is involved, run its documented backward-compatible rollback; never use git reset or delete production data as an emergency shortcut.
- Revoke/rotate a leaked secret immediately, then restart revisions referencing the updated Key Vault value.
- Record incident start/end time, affected student IDs by safe reference, provider request IDs and corrective action.

# 10. End-to-end acceptance tests and launch sequence

## Staging test data

- Use a dedicated CAS collaborator account in the production Entra tenant with reviewer role, plus a separate admin account for role testing.
- Use controlled Gmail/Outlook QA mailboxes. Do not use example.com for email delivery and do not depend on disposable mailbox domains for deliverability conclusions.
- Create one student per scenario with clear QA markers and a cleanup/retention rule.

## Required scenario checklist

| Use case                       | Cases to prove                                                                                                                    |
|--------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| Microsoft collaborator sign-in | Success, cancel, expired state, wrong tenant, non-@cas.cr, inactive user, API unavailable.                                        |
| HubSpot intake                 | Valid form, minimal valid form, repeated event, updated fields, unknown form, bad signature, malformed date, Dataverse outage.    |
| Invitation                     | One click sends once, unknown student, ambiguous match, existing portal user, immediate Resend failure, later bounce/suppression. |
| Temporary password             | Correct credential redirects automatically to Create a new password before dashboard; wrong and expired credentials are safe.     |
| Password change                | Weak/mismatch/reused token, successful change, retry after failure, old temporary password no longer works.                       |
| Forgot password                | Known and unknown emails return the same public message; known mailbox receives new temporary access; rate limit is enforced.     |
| Student dashboard              | Only own student is visible; current phase, missing data and dependency error are distinguished.                                  |
| File upload                    | PDF/JPG/PNG, bad extension, fake signature, active PDF content, 40 MiB limit, partial multi-file failure, SharePoint outage.      |
| Review                         | Approve, replacement with required comment, forbidden student action, stale/concurrent decision and Dataverse failure.            |
| Downloads/templates            | Allowed, missing, forbidden, expired signed URL, real SharePoint item and recorded web URL.                                       |
| Sessions                       | Refresh, sign-out, idle timeout, expired/tampered cookie, student cookie cannot access collaborator portal and vice versa.        |

## Launch order

- 1. Deploy API with production settings but keep HubSpot workflow off and use only controlled tests.

- 2. Deploy both portals; bind domains and finish Entra redirect configuration.
- 3. Run all staging acceptance tests and resolve every P0 finding.
- 4. Enable Resend production sender and delivery webhook; prove accepted, delivered and bounced states.
- 5. Publish HubSpot workflow to a small internal list, reconcile Dataverse, then enable normal enrollment.
- 6. Pilot with a small cohort; monitor daily for one week before broad use.

## 11. Code changes: completed and still required

### Completed in the current working changes

- CAS API
  - Centralized authentication, permissions, student temporary access, forced password change and password recovery.
  - HubSpot signed workflow endpoint with allowlisted form IDs and idempotent Dataverse create/update by email.
  - Professional HTML and plain-text Resend templates; no plaintext password returned to portals or logs.
  - Production Dockerfile; external production bind; Azure PORT support; local health script corrected to port 8081.
- Student Portal
  - Removed embedded/local API and points only to the central CAS API.
  - Temporary-password login automatically enters the password-change flow.
  - Safe handling for malformed successful API responses and missing change tokens.
  - Separate cookie name, production Secure attribute and production Dockerfile.
- Collaborator Portal
  - Removed reviewer mock fallback and direct email/password-reset implementation.
  - Microsoft OAuth is required, raw network/OAuth errors are replaced by a safe administrator message, and malformed token responses are handled.
  - One-click invitation submission is locked against duplicate sends and covered by an AppTest.
  - Separate cookie name, production Secure attribute and production Dockerfile.

### Required before broad production

- Replace JavaScript-written persistent auth cookies with a server-set HttpOnly design, or formally accept and mitigate the risk for a restricted pilot.
- Add Resend email ID persistence, signed delivery webhook processing, bounce/suppression status and a controlled reissue path.
- Add persistent HubSpot event deduplication/replay protection and stale-update rules.
- Move rate limiting to shared storage before API horizontal scaling; until then max replicas = 1.
- Add dependency timeouts/circuit breakers and structured correlation IDs across portal, API, Microsoft, HubSpot and Resend requests.
- Add malware scanning/quarantine for uploaded files and document the release policy.
- Create GitHub Actions and infrastructure-as-code after Azure resource IDs and naming are approved.
- Build and scan all three Docker images in ACR/GitHub Actions; local Docker verification was not possible on this computer.

## Recommended hardening after first launch

- Replace the standard-library ThreadingHTTPServer with a maintained ASGI framework and production server for graceful shutdown, middleware, request IDs and metrics.
- Externalize caches and rate limits, then load-test multiple API replicas.
- Add automated database/schema migrations with backward-compatible deploy order.
- Add a dedicated background job/outbox for emails and analytics so provider latency does not hold open user requests.
- Add Azure Front Door/WAF only after validating WebSocket, forwarded-host and HubSpot signature behavior.

## 12. Risk register and final production checklist

| Priority | Current implementation                                             | Failure mode                                          | Required control                                                      |
|----------|--------------------------------------------------------------------|-------------------------------------------------------|-----------------------------------------------------------------------|
| P0       | JS-readable signed auth cookie contains API user token             | XSS can steal an active token                         | HttpOnly server-side session/BFF or restricted pilot + CSP/XSS review |
| P0       | External portal/OAuth/webhook URLs are local or not yet configured | Login callback, email links or HubSpot signature fail | Bind HTTPS domains and set exact matching values                      |
| P1       | Resend HTTP success shown as invitation sent                       | Later bounce leaves user without usable access        | Persist email ID and process delivery/bounce webhooks                 |
| P1       | HubSpot v2 signature without persistent event dedupe               | Captured/retried stale event may overwrite fields     | Store event ID/hash/time and reject replay/stale update               |
| P1       | In-memory rate limiter/cache                                       | Limits differ between replicas                        | Keep API at one replica or use shared Redis                           |
| P1       | No malware scanner                                                 | Malicious valid-looking file reaches SharePoint       | Quarantine/scan and define release policy                             |
| P1       | Docker not available locally                                       | Image-only dependency/startup defect remains unseen   | Build and scan in ACR/GitHub Actions before release                   |
| P2       | Sending-only Resend key cannot list domains                        | Admin verification cannot be automated with that key  | Verify in dashboard or separate admin credential                      |
| P2       | No visible DMARC TXT response during review                        | Weaker anti-spoofing/deliverability posture           | Confirm all senders, publish staged DMARC and monitor reports         |
| P2       | No CI/CD or IaC yet                                                | Manual drift and slower rollback                      | OIDC GitHub Actions + Bicep/Terraform                                 |
| P2       | Snowflake not integrated                                           | No centralized analytics yet                          | Optional phase-two asynchronous analytics pipeline                    |

## Final go-live checklist

- All P0 gates signed off by named owner; open P1 items have an approved due date and workaround.
- Three immutable images built, scanned and deployed; all automated tests green in CI.
- api.cas.cr, estudiantes.cas.cr and colaboradores.cas.cr resolve over valid HTTPS.
- Entra redirect URI and collaborator sign-in work with allowed and denied accounts.
- HubSpot test creates/updates exactly one QA student and bad signatures are rejected.
- Resend controlled mailbox receives professional invitation and recovery messages; bounce/suppression behavior is visible.
- Temporary password automatically opens new-password page and cannot reach dashboard first.

- Student ownership and reviewer/admin authorization tests pass against real staging data.
- SharePoint uploads/downloads and Dataverse reviews pass, including provider outage behavior.
- Alerts, on-call contact, backup/restore owner and rollback rehearsal are complete.
- Local/test variables are absent from production and no secret appears in Git, image layers or logs.
- Pilot cohort and observation window are approved before full rollout.

# Appendix A. Environment variable matrix

## CAS API

| Variable                         | Source        | Production value                | Caution                 |
|----------------------------------|---------------|---------------------------------|-------------------------|
| CAS_ENVIRONMENT                  | Manual        | prod                            | Must not be local       |
| CAS_API_HOST                     | Manual        | 0.0.0.0                         | Container bind          |
| CAS_API_PORT                     | Manual        | 8080                            | Matches ingress         |
| CAS_API_REQUIRE_AUTH             | Manual        | 1                               | Fail closed             |
| CAS_API_AUTH_TOKEN               | Key Vault     | Random                          | Also in both portals    |
| CAS_API_USER_TOKEN_SECRET        | Key Vault     | Random                          | Independent signing key |
| CAS_API_PASSWORD_RESET_SECRET    | Key Vault     | Random                          | Independent signing key |
| CAS_API_DATAVERSE_TENANT_ID      | Manual/secret | Tenant ID                       | Optima tenant           |
| CAS_API_DATAVERSE_CLIENT_ID      | Manual/secret | App ID                          | Least privilege         |
| CAS_API_DATAVERSE_CLIENT_SECRET  | Key Vault     | Secret                          | Rotate                  |
| CAS_API_DATAVERSE_URL            | Manual        | https://...crm.dynamics.com     | No trailing slash       |
| CAS_API_SHAREPOINT_TENANT_ID     | Manual/secret | Tenant ID                       | CAS tenant              |
| CAS_API_SHAREPOINT_CLIENT_ID     | Manual/secret | App ID                          | Least privilege         |
| CAS_API_SHAREPOINT_CLIENT_SECRET | Key Vault     | Secret                          | Rotate                  |
| CAS_API_SHAREPOINT_HOSTNAME      | Manual        | cascostarica.sharepoint.com     | Exact host              |
| CAS_API_SHAREPOINT_SITE_PATH     | Manual        | /sites/...                      | Exact site              |
| CAS_API_SHAREPOINT_BASE_FOLDER   | Manual        | CAS Drive/OPTIMA/...            | Existing folder         |
| RESEND_API_KEY                   | Key Vault     | re_...                          | Sending scope           |
| RESEND_FROM_EMAIL                | Manual        | CAS Student Services            | Verified domain         |
| CAS_PORTAL_URL                   | Manual        | https://estudiantes.cas.cr      | Email link              |
| CAS_HUBSPOT_CLIENT_SECRET        | Key Vault     | Secret                          | Developer app           |
| CAS_HUBSPOT_ALLOWED_FORM_IDS     | Manual        | Comma-separated IDs             | Production only         |
| CAS_HUBSPOT_WEBHOOK_PUBLIC_URL   | Manual        | https://api.cas.cr/webhooks/... | Exact signed URI        |
| CAS_RATE_LIMIT_DISABLED          | Unset         |                                 | Never disable in prod   |



## Student Portal

| Variable              | Source    | Production value   | Caution                 |
|-----------------------|-----------|--------------------|-------------------------|
| CAS_ENVIRONMENT       | Manual    | prod               | Disables local shortcut |
| CAS_API_BASE_URL      | Manual    | https://api.cas.cr | HTTPS only              |
| CAS_API_AUTH_TOKEN    | Key Vault | Same as API        | Service secret          |
| AUTH_COOKIE_SECRET    | Key Vault | Unique random      | Not collaborator value  |
| CAS_TEST_STUDENT_ID   | Unset     |                    | Must be absent          |
| CAS_TEST_STUDENT_NAME | Unset     |                    | Must be absent          |

## Collaborator Portal

| Variable                          | Source        | Production value             | Caution              |
|-----------------------------------|---------------|------------------------------|----------------------|
| CAS_ENVIRONMENT                   | Manual        | prod                         | Requires real OAuth  |
| CAS_API_BASE_URL                  | Manual        | https://api.cas.cr           | HTTPS only           |
| CAS_API_AUTH_TOKEN                | Key Vault     | Same as API                  | Service secret       |
| AUTH_COOKIE_SECRET                | Key Vault     | Unique random                | Not student value    |
| CAS_MICROSOFT_TENANT_ID           | Manual/secret | CAS tenant ID                | Single tenant        |
| CAS_MICROSOFT_CLIENT_ID           | Manual/secret | App ID                       | Entra registration   |
| CAS_MICROSOFT_CLIENT_SECRET       | Key Vault     | Secret                       | Rotate before expiry |
| CAS_MICROSOFT_REDIRECT_URL        | Manual        | https://colaboradores.cas.cr | Exact Entra match    |
| CAS_REVIEWER_IDLE_TIMEOUT_MINUTES | Manual        | 60                           | Policy decision      |
| CAS_STREAMLIT_UI_DEBUG            | Unset         |                              | No production debug  |

## Appendix B. Official documentation links

These primary sources were checked for the portal paths and platform behavior described in this guide. Portal labels can change; search by the resource/feature name if Microsoft, HubSpot, Resend or Snowflake adjusts navigation.

- [Azure Container Apps: deploy an existing image](https://learn.microsoft.com/en-us/azure/container-apps/get-started-existing-container-image-portal)  
https://learn.microsoft.com/en-us/azure/container-apps/get-started-existing-container-image-portal
- [Azure Container Registry portal quickstart](https://learn.microsoft.com/en-ie/azure/container-registry/container-registry-get-started-portal)  
https://learn.microsoft.com/en-ie/azure/container-registry/container-registry-get-started-portal
- [Azure Container Apps secrets and Key Vault references](https://learn.microsoft.com/en-us/azure/container-apps/manage-secrets)  
https://learn.microsoft.com/en-us/azure/container-apps/manage-secrets
- [Azure Container Apps environment variables](https://learn.microsoft.com/en-us/azure/container-apps/environment-variables)  
https://learn.microsoft.com/en-us/azure/container-apps/environment-variables
- [Azure Container Apps health probes](https://learn.microsoft.com/en-us/azure/container-apps/health-probes)  
https://learn.microsoft.com/en-us/azure/container-apps/health-probes

- [Azure Container Apps custom domains and managed certificates](https://learn.microsoft.com/en-sg/azure/container-apps/custom-domains-managed-certificates)  
<https://learn.microsoft.com/en-sg/azure/container-apps/custom-domains-managed-certificates>
- [Azure Container Apps session affinity](https://learn.microsoft.com/en-in/azure/container-apps/sticky-sessions)  
<https://learn.microsoft.com/en-in/azure/container-apps/sticky-sessions>
- [Azure Container Apps revisions and rollback concepts](https://learn.microsoft.com/en-us/azure/container-apps/revisions)  
<https://learn.microsoft.com/en-us/azure/container-apps/revisions>
- [Azure Container Apps log streaming](https://learn.microsoft.com/en-us/azure/container-apps/log-streaming)  
<https://learn.microsoft.com/en-us/azure/container-apps/log-streaming>
- [Azure/GitHub authentication with OIDC](https://learn.microsoft.com/en-us/azure/developer/github/connect-from-azure-openid-connect)  
<https://learn.microsoft.com/en-us/azure/developer/github/connect-from-azure-openid-connect>
- [Azure Key Vault portal quickstart](https://learn.microsoft.com/en-us/azure/key-vault/secrets/quick-create-portal)  
<https://learn.microsoft.com/en-us/azure/key-vault/secrets/quick-create-portal>
- [Streamlit Docker deployment](https://docs.streamlit.io/deploy/tutorials/docker)  
<https://docs.streamlit.io/deploy/tutorials/docker>
- [Streamlit configuration and security options](https://docs.streamlit.io/develop/api-reference/configuration/config.toml)  
<https://docs.streamlit.io/develop/api-reference/configuration/config.toml>
- [HubSpot workflow webhooks](https://knowledge.hubspot.com/workflows/how-do-i-use-webhooks-with-hubspot-workflows)  
<https://knowledge.hubspot.com/workflows/how-do-i-use-webhooks-with-hubspot-workflows>
- [HubSpot request signature validation](https://developers.hubspot.com/docs/apps/developer-platform/build-apps/authentication/request-validation)  
<https://developers.hubspot.com/docs/apps/developer-platform/build-apps/authentication/request-validation>
- [Resend webhook event types](https://resend.com/docs/webhooks/event-types)  
<https://resend.com/docs/webhooks/event-types>
- [Resend storing webhook data](https://resend.com/docs/dashboard/webhooks/how-to-store-webhooks-data)  
<https://resend.com/docs/dashboard/webhooks/how-to-store-webhooks-data>
- [Resend deliverability guidance](https://resend.com/docs/dashboard/emails/deliverability-insights)  
<https://resend.com/docs/dashboard/emails/deliverability-insights>
- [Snowflake workload identity federation](https://docs.snowflake.com/en/user-guide/workload-identity-federation)  
<https://docs.snowflake.com/en/user-guide/workload-identity-federation>
- [Snowflake role-based access control](https://docs.snowflake.com/en/user-guide/security-access-control-configure)  
<https://docs.snowflake.com/en/user-guide/security-access-control-configure>
- [Snowflake warehouses](https://docs.snowflake.com/en/user-guide/warehouses-tasks)  
<https://docs.snowflake.com/en/user-guide/warehouses-tasks>
- [Snowflake network rules](https://docs.snowflake.com/en/user-guide/network-rules)  
<https://docs.snowflake.com/en/user-guide/network-rules>
- [Snowflake Python connector](https://docs.snowflake.com/en/developer-guide/python-connector/python-connector-install)  
<https://docs.snowflake.com/en/developer-guide/python-connector/python-connector-install>

**Next concrete action**

Create rg-cas-prod, the Container Registry and Key Vault first. Then build immutable images in ACR and deploy a staging revision of the API. Do not change HubSpot, Entra or production DNS until the generated Azure URLs are healthy and the secret matrix is complete.